

Durcissement Fondamental Linux

Objectifs

1. Sécuriser le service OpenSSH selon les recommandations du référentiel ANSSI.
2. Forcer le principe du moindre privilège à la création de fichiers et répertoires via l'Umask 027.
3. Réaliser l'inventaire et la remédiation des binaires à privilèges SUID (vecteurs GTFOBins).
4. Assainir et sécuriser la configuration de la délégation de privilèges sudo.
5. Appliquer les premiers paramètres de durcissement du noyau (sysctl) identifiés lors de l'audit Lynis.

Verrouillage du service d'accès distant (OpenSSH)

Le protocole SSH est la cible numéro un des attaques par force brute et credential stuffing. La configuration par défaut de la plupart des distributions autorise des comportements jugés inacceptables par l'ANSSI.

1.1 Désactivation du compte root direct

1. Ouvrez le fichier de configuration principal d'OpenSSH :
`sudo nano /etc/ssh/sshd_config`
2. Repérez la directive PermitRootLogin (supprimez le # initial si la ligne est commentée) et appliquez la valeur stricte :
`PermitRootLogin no`
3. Ajoutez une restriction explicite sur les comptes autorisés à se connecter en fin de fichier :
`AllowUsers formation`
4. Sauvegardez (Ctrl + O, Entrée) et quittez (Ctrl + X).

1.2 Test de syntaxe et redémarrage du service

Ne relancez jamais un service SSH en production sans tester préalablement la syntaxe de sa configuration :

1. Validez la cohérence du fichier :
`sudo sshd -t`

(Si la commande ne renvoie aucune sortie texte, la configuration est exempte d'erreur).

2. Appliquez les modifications en rechargeant le démon :
`sudo systemctl restart ssh`

3. **Validation** : Ouvrez une console alternative ou tentez une connexion en root :

ssh root@127.0.0.1

Résultat attendu : La connexion doit être rejetée immédiatement (Permission denied), confirmant que seul le compte formation est autorisé.

Cloisonnement du système de fichiers via l'Umask (ANSSI)

Par défaut, l'Umask standard (022) accorde des permissions de lecture à l'ensemble des utilisateurs du système (755 pour les répertoires, 644 pour les fichiers). L'ANSSI impose un Umask à 027 pour interdire tout accès au groupe "Autres" (Other = 0).

2.1 Modification de la directive globale

1. Éditez la configuration générale de création des sessions :
`sudo nano /etc/login.defs`
2. Recherchez la ligne débutant par UMASK et modifiez-la pour forcer la valeur recommandée :
`UMASK 027`
3. Sauvegardez (Ctrl + O, Entrée) et quittez (Ctrl + X).

2.2 Validation des permissions par défaut

1. Déconnectez-vous de votre terminal puis reconnectez-vous pour charger le nouvel environnement :
`exit`

(Puis rouvrez la session avec le compte formation).
2. Créez un répertoire et un fichier de test :
`mkdir dossier_confidential`
`touch dossier_confidential/document.txt`
3. Inspectez les permissions créées :
`ls -ld dossier_confidential`
`ls -l dossier_confidential/document.txt`

Résultats attendus :

- Répertoire : drwxr-x--- (octal ⁷⁵⁰)
- Fichier : -rw-r----- (octal ⁶⁴⁰)
- Aucun droit n'est accordé aux tiers non membres du groupe (---).

Audit et neutralisation des binaires SUID / SGID

Un exécutable pourvu du bit SUID s'exécute avec les privilèges du propriétaire du fichier (root). Les attaquants s'appuient sur le catalogue d'abus **GTFOBins** pour exploiter ces binaires et contourner les restrictions.

3.1 Cartographie exhaustive

1. Identifiez tous les binaires SUID présents sur la machine :
`sudo find / -perm -4000 -type f -exec ls -la {} + 2>/dev/null`
2. Analysez les résultats :
 - Binaires indispensables au fonctionnement standard : `/usr/bin/passwd`, `/usr/bin/sudo`, `/usr/bin/su`.
 - Binaires pouvant présenter un risque accru ou superflus : `/usr/bin/ping`, compilateurs, outils d'archivage ou utilitaires de trace réseau.

3.2 Révocation du bit SUID sur un outil cible

1. Neutralisez le bit SUID sur un utilitaire non critique (ex. ping) :
`sudo chmod u-s /usr/bin/ping`
2. Vérifiez le changement de mode :
`ls -la /usr/bin/ping`

Résultat attendu : Les droits doivent passer de `-rwsr-xr-x` à `-rwxr-xr-x` (le bit `s` est remplacé par `x`).

Durcissement des privilèges Sudo

L'audit Lynis du Jour 1 a remonté une anomalie sur les permissions du répertoire `/etc/sudoers.d`. Nous allons assainir les droits et sécuriser les délégations.

4.1 Correction des droits sur `/etc/sudoers.d`

1. Vérifiez les permissions actuelles du répertoire :
`ls -ld /etc/sudoers.d`
2. Rétablissez les permissions strictes conformes aux exigences du démon sudo :
`sudo chmod 750 /etc/sudoers.d`
`sudo chmod 440 /etc/sudoers.d/*`
3. Validez l'état des droits :
`ls -la /etc/sudoers.d`

Application des durcissements du Noyau (Sysctl)

Pour remédier aux statuts [DIFFÉRENT] observés dans le rapport Lynis, nous allons appliquer directement dans le noyau Linux les contre-mesures recommandées contre les fuites de mémoire et les détournements réseau.

5.1 Création du fichier de durcissement ANSSI

1. Créez un fichier de configuration dédié dans l'arborescence système :
`sudo nano /etc/sysctl.d/99-durcissement-anssi.conf`
2. Ajoutez les paramètres suivants :
Interdiction des Core Dumps pour les exécutable à privilèges (SUID)
`fs.suid_dumpable = 0`

Protection contre le détournement de routes ICMP (Attaques Man-in-the-Middle)
`net.ipv4.conf.all.accept_redirects = 0`
`net.ipv4.conf.default.accept_redirects = 0`
`net.ipv6.conf.all.accept_redirects = 0`
`net.ipv6.conf.default.accept_redirects = 0`

Interdiction de l'envoi de paquets ICMP de redirection
`net.ipv4.conf.all.send_redirects = 0`

Journalisation des paquets suspects (adresses impossibles / martians)
`net.ipv4.conf.all.log_martians = 1`
3. Sauvegardez (Ctrl + O, Entrée) et quittez (Ctrl + X).

5.2 Chargement à chaud et validation

1. Forcez le noyau à charger immédiatement les nouvelles directives sans redémarrer :
`sudo sysctl -p /etc/sysctl.d/99-durcissement-anssi.conf`
2. Contrôlez que les paramètres actifs correspondent bien à la politique :
`sysctl fs.suid_dumpable`
`sysctl net.ipv4.conf.all.accept_redirects`

Résultat attendu : Les deux valeurs retournées par le système doivent être strictement à 0.

Livrable et Critères d'évaluation

- Le fichier `/etc/ssh/sshd_config` bloque l'accès direct de root et restreint les comptes autorisés.
- Tout dossier créé après reconnexion respecte strictement les permissions 750

(drwxr-x---) et tout fichier 640 (-rw-r-----).

- La commande ping ne porte plus le bit SUID (chmod u-s validé).
- Les permissions de /etc/sudoers.d sont verrouillées en 750 et les fichiers internes en 440.
- Les clés sysctl de sécurité noyau sont chargées et actives à 0.